

Augmented Offense — Module 4: Cryptobionic security (VivoKey)

Len Noe & Dr. Gregory Carpenter · CW PENSEC

Phone-native · ~15 min (1:23–1:38) · the exhale

Module 4 — Cryptobionic security: a credential with nothing to clone

Implant analog: Apex / Spark. **Tool:** your phone + the **Apex Manager** app.

Use the app named “Apex Manager” (by VivoKey) — *not* the generic VivoKey or Fidesmo app. Apex Manager is the one that reads the Apex/VivoKey test card’s secure element. It’s free on the **Apple App Store** and **Google Play**; have attendees install it during the opening (project the store QR). **This is the defensive capstone** — the room has broken three things; now show the one that holds and why.

Objective attendees reach

Scan the VivoKey test card and see challenge-response / cryptographic identity where the keys **never leave the secure element** — no dump, no UID to forge, no replay.

Materials

- Attendee phone (iPhone or Android) with the **Apex Manager** app installed
 - 1× VivoKey test card per attendee (or pass a few around)
-

Step by step (both platforms)

1. Open the **Apex Manager** app.
 2. **Scan** the VivoKey test card (hold it to the top-back of the phone).
 3. Watch the cryptographic identity / challenge-response flow.
 4. **Contrast out loud against Modules 2–3:** try to “dump” it — there’s nothing to dump. There’s no UID to forge and no replay.
-

Why it matters

This is the implant you can scan and still never become. Everything you broke earlier assumed the credential was a secret you could read — this one never hands you the secret.

Defensive synthesis

Pull the three broken primitives into adversary workflow and defense:

- **Attacker-as-hardware** collapses proximity and intent assumptions — the operator *is* the tool.
 - **Access control:** UID $\neq$ identity. Retire LF prox and bare MIFARE Classic; move to challenge-response / identity-bound credentials (this card).
 - **NFC/BLE policy:** treat tap-to-URL as untrusted input; MDM on background NDEF; behavior training against redirect chains.
 - **Detection:** what does defender *visibility* look like when the tool is subdermal? Name the gap — that’s the research contribution (see the Defense guide).
 - **Cross-domain:** cyber + physical + cognitive/IO — the DEF CON abstract’s core claim.
-

Failure modes

Symptom	Cause	Fix
App won’t scan	NFC off / wrong phone position	enable NFC, hold card to the top of the phone
Attendees “want to clone it too”	that’s the point	there’s nothing to clone — that’s the whole lesson

Do not cut

This module resolves the tension of the whole session. If time is tight, cut depth from Module 3, never this.

Safety

Read-only scan. Nothing is written, forged, or captured.

Presenters

- **Len Noe (213)** — <https://www.linkedin.com/in/len-noe/>
- **Dr. Gregory Carpenter (JunkBond)** — <https://www.linkedin.com/in/gcarpenter-cw-pensec/>